

SECURITY ASSESSMENT REPORT

Endpoint Security Posture Assessment

ATT&CK-Aligned Breach & Attack Simulation
Executive & Technical Report — Confidential

ENDPOINT audspectserver	IP / ENVIRONMENT 192.168.10.78 · Production
OPERATING SYSTEM Linux/amd64 (Ubuntu 24.04.4 LTS)	LOGGED-IN USER root
ASSESSMENT DATE 03 Sep 2026, 11:42 UTC	LAST SCENARIO Linux Defense Evasion - Log Clearing, Timestomping, History Wipe
AGENT STATUS ● idle	

CONTENTS

Table of Contents

1	Executive Summary
2	Assessment Summary
3	Top Risk Drivers
4	Risk Summary
5	Asset Context
6	Kill-Chain Path
7	Attack Flow
8	Attack Path Validation
9	MITRE ATT&CK Tactic Summary
10	Threat Actor Readiness
10b	EPSS Priority Index
12	Assessment Insights
13	Action Plan
14	Regulatory Compliance Status
15	Scenario Run History
16	Technical Findings
17	Environment Restoration
18	Detection Validation
19	Coverage Analytics
20	Technical Appendix — ATT&CK Glossary

SECTION 1

Executive Summary

0.0%

PREVENTION

OVERALL RISK SCORE

100 / 100

Critical

Exposure: Critical

14 / 14 techniques evaded

PREVENTION SCORE

0.0%

DETECTION SCORE

N/A

TECHNIQUES MISSED

0 / 0

TECHNIQUES PREVENTED

0 / 0

ATT&CK KILL-CHAIN COVERAGE

DEFENSE EVASION

0.0%

14 tested

PRIVILEGE ASSESSMENT

15

Techniques Tested

13

Standard User

2

Required Elevation

▲ 13 technique(s) succeeded from a standard user account — exploitable immediately after initial access, before any privilege escalation. Additionally, 2 technique(s) required elevated privileges to succeed.

Executive Conclusion

This assessment executed 14 techniques against the endpoint, of which 14 were not prevented (prevention score 0%, critical exposure). Protection is weakest in Defense Evasion (0% prevented). Detection effectiveness could not be evaluated due to missing host telemetry. Immediate focus should be placed on Defense Evasion.

SECTION 2

Assessment Summary

PREVENTION SCORE

0.0%

Severity-weighted pass rate

DETECTION SCORE

N/A

No host telemetry — detection not measurable

EXPOSURE LEVEL

Critical

Derived from prevention effectiveness

PENETRATION RATIO

14/14

100% of executed techniques got through

TREND VS. PREVIOUS

no change

Prevention pts vs previous (0.0% → 0.0%)

ATTACK SURFACE AGE

Exposed weakness present for 0 days

Oldest finding: **T1070** (Log Files Not World-Readable (/var/log)) · Severity: **Medium** · Status: **WITHIN-SLA**

ENDPOINT STABILITY CHECK

BEFORE RUNNING

CPU: **2.5%** · RAM: **4.5 GB** · Disk: **68.1%**

AFTER RUNNING

CPU: **2.7%** · RAM: **4.5 GB** · Disk: **68.1%**

HEALTH IMPACT

Negligible

Tactic Coverage (breadth)	7.1% of 14 ATT&CK tactics	Defense Rate	0.0% tactics fully blocked
Kill-Chain Amplifier	1.0x	Mean Time-to-Detect	—

Executed	14	Succeeded	0
Failed	14		
Skipped (Policy)	0	Skipped (Content)	0
Skipped (Platform)	2		
Scenario Coverage	3/15 (20%)		
Eligible Coverage	3/15 (20%)		

Attempted	17	Valid (scored)	14
Environmental Errors	1	Skipped	2
Result Confidence	High		

EXECUTION CONTEXT (PRIVILEGE)

Per-step privilege context from multi-context execution. **Legacy** steps ran in the agent's default context (requires_priv not yet annotated). **User→Admin** indicates a requested user-context step that fell back to admin because no interactive session was available. Prevention rate = steps blocked / steps attempted per tier.

TIER	STEPS	PREVENTED	PREVENTION RATE
User (interactive)	13	0	0%
Admin (elevated)	2	0	0%
Legacy (unannotated)	2	0	0%

SECTION 3

Top Risk Drivers

The techniques whose failures account for the most lost prevention points (severity-weighted, the same weighting as the headline score). "Score points" is how much of the 100-point scale each technique's failures account for — not a guaranteed gain from any single fix.

#	TECHNIQUE	TACTIC	SEVERITY	FAILURES	SCORE POINTS
1	T1070.003 Indicator Removal: Clear Command History	Defense Evasion	● High	9	64.3
2	T1070.006 Indicator Removal	Defense Evasion	● High	4	28.6
3	T1036.005 Masquerading: Match Legitimate Name or Location	Defense Evasion	● High	1	7.1

SECTION 4

Risk Summary

Business-objective risk derived from the per-tactic outcome: **High** when most tested techniques in the objective went unprevented, **Medium** when some did, **Low** when all were blocked. Objectives with no executed techniques are omitted.

BUSINESS OBJECTIVE	ATT&CK TACTIC	RISK	TESTED	UNPREVENTED
Defense Evasion	Defense Evasion	● High	14	14

SECTION 5

Asset Context

Hostname	audspecterver
IP Address	192.168.10.78
Operating System	Linux/amd64 (Ubuntu 24.04.4 LTS)
Logged-in User	root
Environment	Production
Agent Status	idle
Last Update	03 Sep 2026, 11:47 UTC

REPORTED SECURITY TOOLING

LSM: AppArmor (enabled, 61/156 profiles enforcing)

Warning: Cleanup failed

Out of the executed techniques, 6 failed to clean up successfully. Residual simulation artifacts (files or registry entries) may remain on the endpoint. SOC/security teams should review the logs and technique details below to perform manual remediation.

SECTION 6

Kill-Chain Path

The chain of kill-chain phases this endpoint's gaps actually permit — built strictly from observed unprevented techniques, ordered by ATT&CK phase. No hypothetical or inferred steps.

ATTACK SIMULATION TIMELINE



PHASE	UNPREVENTED TECHNIQUES
Defense Evasion	T1070.003 — Indicator Removal: Clear Command History T1070.006 — Indicator Removal T1036.005 — Masquerading: Match Legitimate Name or Location

SECTION 7

Attack Flow

Per-technique execution outcome ordered by ATT&CK kill-chain phase. Each row shows which security control acted (or failed to act) on the technique and the resulting verdict: **Blocked** (control prevented execution), **Detected** (logged and alerted but not stopped), **Logged** (telemetry captured, no alert), or **Bypassed** (no control observed the technique).



TECHNIQUE	NAME	TACTIC	VERDICT	SECURITY CONTROL	SEVERITY	DURATION
DEFENSE EVASION						
T1070.003	Indicator Removal: Clear Command History T1070.003 - Test 1: Clear Bash history (rm)	Defense Evasion	Bypassed — Undetected	—	High	5ms
T1070.003	Indicator Removal: Clear Command History T1070.003 - Test 2: Clear Bash history (echo)	Defense Evasion	Bypassed — Undetected	—	High	2ms
T1070.003	Indicator Removal: Clear Command History T1070.003 - Test 3: Clear Bash history (cat dev/null)	Defense Evasion	Bypassed — Undetected	—	High	3ms
T1070.003	Indicator Removal: Clear Command History T1070.003 - Test 4: Clear Bash history (ln dev/null)	Defense Evasion	Bypassed — Undetected	—	High	3ms

TECHNIQUE	NAME	TACTIC	VERDICT	SECURITY CONTROL	SEVERITY	DURATION
T1070.003	Indicator Removal: Clear Command History T1070.003 - Test 5: Clear Bash history (truncate)	Defense Evasion	Bypassed — Undetected	—	High	3ms
T1070.003	Indicator Removal: Clear Command History T1070.003 - Test 6: Clear history of a bunch of shells	Defense Evasion	Bypassed — Undetected	—	High	1ms
T1070.003	Indicator Removal: Clear Command History T1070.003 - Test 7: Clear and Disable Bash History Logging	Defense Evasion	Bypassed — Undetected	—	High	23ms
T1070.003	Indicator Removal: Clear Command History T1070.003 - Test 8: Use Space Before Command to Avoid Logging to History	Defense Evasion	Bypassed — Undetected	—	High	4ms
T1070.003	Indicator Removal: Clear Command History T1070.003 - Test 9: Disable Bash History Logging with SSH -T	Defense Evasion	Error	—	High	23ms
T1070.003	Indicator Removal: Clear Command History T1070.003 - Test 10: Clear Docker Container Logs	Defense Evasion	Bypassed — Undetected	—	High	412ms
T1070.006	Indicator Removal T1070.006 - Test 1: Set a file's access timestamp	Defense Evasion	Bypassed — Undetected	—	High	23ms
T1070.006	Indicator Removal T1070.006 - Test 2: Set a file's modification timestamp	Defense Evasion	Bypassed — Undetected	—	High	26ms
T1070.006	Indicator Removal T1070.006 - Test 3: Set a file's creation timestamp	Defense Evasion	Bypassed — Undetected	—	High	29ms
T1070.006	Indicator Removal T1070.006 - Test 4: Modify file timestamps using reference file	Defense Evasion	Bypassed — Undetected	—	High	71ms
T1036.005	Masquerading: Match Legitimate Name or Location T1036.005 - Test 1: Execute a process from a directory masquerading as the current parent directory	Defense Evasion	Bypassed — Undetected	—	High	53ms
T1070.002	Indicator Removal T1070.002	Defense Evasion	Skipped	—	High	—
T1562.001	Impair Defenses: Disable or Modify Tools T1562.001	Defense Evasion	Skipped	—	High	—

SECTION 8

Attack Path Validation

Lateral-movement reachability mapped as a graph of hosts, users and groups. Recon/relationship analysis only — no exploitation, no propagation. It answers what ART and Caldera cannot: if a host is compromised, how far can an attacker move and can they reach Domain Admin or a crown jewel?

No attack-path data has been collected yet. Enable the `attackpath.collect` task on enrolled agents to map lateral-movement reachability, blast radius, segmentation, and crown-jewel exposure across the fleet.

MITRE ATT&CK Tactic Summary

Per-tactic coverage (techniques tested), prevention rate, detection rate, and mean time-to-detect. MTTD shows "—" when detection latency was not measured. Tactics with no tested techniques are omitted.

TACTIC	WEIGHT	COVERAGE	PREVENTED	DETECTED	MTTD	PREVENTED / DETECTED / MISSED
Defense Evasion	● High	14 tested	0%	0% (0/14)	—	

SECTION 10

Threat Actor Readiness

For each ATT&CK threat group whose techniques overlap this assessment, how well are your controls positioned? Derived from the MITRE ATT&CK knowledge base — no external feed required. Worst prevention readiness shown first.

Prevention Readiness: % of tested techniques that were blocked. **Detection Readiness:** % of tested techniques that were blocked or detected (alert raised). The gap between the two reveals how much you rely on detection-only coverage.

THREAT ACTOR / GROUP	TESTED / TOTAL	COVERAGE	PREVENTION READINESS	DETECTION READINESS	TREND	READINESS	CONFIDENCE
APT5	3 / 28	11%	0.0% 0 prevented	0.0% +0 detected	—	Low	Low Confidence (3 tested)

Groups with fewer than 3 tested techniques are excluded. Technique attribution sourced from MITRE ATT&CK®. © The MITRE Corporation.

SECTION 10B

EPSS Priority Index

Composite prioritisation combining CISA KEV active-exploitation status, FIRST EPSS exploitation probability, and ATT&CK threat-actor usage frequency. Techniques with higher scores represent the greatest unremediated risk.

Formula: **KEV** +40 pts · **EPSS** ≥90th %ile +30 pts · ≥70th +20 pts · ≥50th +10 pts · **Threat Actors** ≥5 +20 pts · ≥2 +10 pts · **Unblocked** +10 pts.

#	TECHNIQUE	TACTIC	SCORE	TIER	KEV	EPSS	ACTORS	VERDICT
1	T1036.005 Masquerading: Match Legitimate Name or Location	Defense Evasion	30	Medium	—	—	15	UNBLOCKED
2	T1070.003 Indicator Removal: Clear Command History	Defense Evasion	30	Medium	—	—	7	UNBLOCKED
3	T1070.006 Indicator Removal	Defense Evasion	30	Medium	—	—	11	UNBLOCKED

EPSS scores from FIRST.org (offline snapshot). KEV from CISA Known Exploited Vulnerabilities catalog. ATT&CK attribution from MITRE © The MITRE Corporation. CVE↔technique relationships shown here are Active with High/Medium confidence only — Low-confidence (illustrative) links are excluded from this score.

SECTION 12

Assessment Insights

MOST PROTECTED

Defense Evasion

0% prevented across 14 executed techniques

LEAST PROTECTED

Defense Evasion

0% prevented across 14 executed techniques

No host telemetry was collected this run — detection effectiveness could not be measured (the agent may be offline or an older build). Undetected counts reflect missing measurement, not confirmed evasion.

SECTION 13

Action Plan

Remediations ordered by the prevention-score points their failures account for. The points quantify current exposure attributable to each tactic — they are not a promised score gain, since a single control may not resolve every underlying finding.

Priority	Tactic / Objective	Accounts For	Failures	Recommended Action
1	Defense Evasion Defense Evasion	100.0 pts	14	Enable tamper protection, ASR rules, and AMSI; alert on security-tool disabling.

SECTION 14

Regulatory Compliance Status

Compliance percentages are derived from BAS evidence over the BAS-testable control subset. A control is Passing when all mapped techniques passed; Failing when at least one failed; Untested when no mapped techniques were included in the run. Manual controls are governance/process requirements (board policy, asset inventory, risk-assessment cadence, IR/DR planning, data residency) that cannot be validated by simulation and require manual attestation — they are excluded from the Compliance and Coverage percentages.

Compliance data unavailable.

SECTION 15

Scenario Run History

Date	Scenario	Status	Risk Score	Classification	Prevention	Exposure	Tested	Failed
03 Sep 2026, 11:42 UTC	Linux Defense Evasion - Log Clearing, Timestomping, History Wipe	completed	100	Critical	0.0%	100.0%	17	14

SECTION 16

Technical Findings

Critical and High severity techniques that executed successfully — the associated controls did **not** prevent the attack. Each card includes the specific blocking control (if any), detection source, and residual artifact state.

🚩 HIGH

Indicator Removal: Clear Command History

T1070.003 - Test 1: Clear Bash history (rm)
— APT41, APT5, Aquatic Panda

T1070.003 · Defense Evasion · Duration: 5ms · ART

WHAT HAPPENED

Security control did not prevent this technique — it executed without being blocked.

EXECUTED AS

User

⚠️ Succeeded without administrator privileges. This technique is exploitable from any initial-access scenario — phishing, malicious document, or compromised standard account — before privilege escalation occurs. Prioritise remediation.

BLOCKED BY

❌ None — no control prevented this technique

DETECTION

❌ No detection — technique executed unseen

EXECUTION EVIDENCE

Exec Verdict

FAIL — technique ran to completion; no control blocked execution

Duration

5 ms

Framework

ART

CLEANUP & RESIDUAL RISK

Residual Risk

—

⚠️ BUSINESS IMPACT

Security controls were bypassed on this endpoint. An attacker operating in this state can conduct further activity with a greatly reduced chance of detection or incident response.

▶️ RECOMMENDED REMEDIATION

1) Enable tamper protection on all EDR/AV solutions; alert on protection disablement. 2) Restrict PowerShell to ConstrainedLanguageMode and enable AMSI. 3) Enable Script Block Logging (Event ID 4104) and forward to SIEM. 4) Monitor for security service termination and log clearing events.

▶️ REMEDIATION PLAN

PRIORITY

High

ESTIMATED EFFORT

Days

OWNER

Endpoint Security Team

HOW TO VERIFY FIX

Enable additional EDR behavioral rules and Tamper Protection. Re-run evasion test — EDR must detect or block. Verify Tamper Protection is active on all endpoints.

↑ HIGH

Indicator Removal: Clear Command History

T1070.003 - Test 2: Clear Bash history (echo)

— APT41, APT5, Aquatic Panda

T1070.003 · Defense Evasion · Duration: 2ms · ART

WHAT HAPPENED

Security control did not prevent this technique — it executed without being blocked.

EXECUTED AS

User

△ Succeeded without administrator privileges. This technique is exploitable from any initial-access scenario — phishing, malicious document, or compromised standard account — before privilege escalation occurs. Prioritise remediation.

BLOCKED BY

✗ None — no control prevented this technique

DETECTION

✗ No detection — technique executed unseen

EXECUTION EVIDENCE

Exec Verdict

FAIL – technique ran to completion; no control blocked execution

Duration

2 ms

Framework

ART

CLEANUP & RESIDUAL RISK

Residual Risk

—

△ BUSINESS IMPACT

Security controls were bypassed on this endpoint. An attacker operating in this state can conduct further activity with a greatly reduced chance of detection or incident response.

▶ RECOMMENDED REMEDIATION

1) Enable tamper protection on all EDR/AV solutions; alert on protection disablement. 2) Restrict PowerShell to ConstrainedLanguageMode and enable AMSI. 3) Enable Script Block Logging (Event ID 4104) and forward to SIEM. 4) Monitor for security service termination and log clearing events.

▶ REMEDIATION PLAN

PRIORITY

High

ESTIMATED EFFORT

Days

OWNER

Endpoint Security Team

HOW TO VERIFY FIX

Enable additional EDR behavioral rules and Tamper Protection. Re-run evasion test — EDR must detect or block. Verify Tamper Protection is active on all endpoints.

↑ HIGH

Indicator Removal: Clear Command History

T1070.003 - Test 3: Clear Bash history (cat dev/null)

— APT41, APT5, Aquatic Panda

T1070.003 · Defense Evasion · Duration: 3ms · ART

✗ EVADED

WHAT HAPPENED

Security control did not prevent this technique — it executed without being blocked.

EXECUTED AS

User

△ Succeeded without administrator privileges. This technique is exploitable from any initial-access scenario — phishing, malicious document, or compromised standard account — before privilege escalation occurs. Prioritise remediation.

BLOCKED BY

✗ None — no control prevented this technique

DETECTION

✗ No detection — technique executed unseen

EXECUTION EVIDENCE

Exec Verdict

FAIL — technique ran to completion; no control blocked execution

Duration

3 ms

Framework

ART

CLEANUP & RESIDUAL RISK

Residual Risk

—

△ BUSINESS IMPACT

Security controls were bypassed on this endpoint. An attacker operating in this state can conduct further activity with a greatly reduced chance of detection or incident response.

► RECOMMENDED REMEDIATION

1) Enable tamper protection on all EDR/AV solutions; alert on protection disablement. 2) Restrict PowerShell to ConstrainedLanguageMode and enable AMSI. 3) Enable Script Block Logging (Event ID 4104) and forward to SIEM. 4) Monitor for security service termination and log clearing events.

► REMEDIATION PLAN

PRIORITY

High

ESTIMATED EFFORT

Days

OWNER

Endpoint Security Team

HOW TO VERIFY FIX

Enable additional EDR behavioral rules and Tamper Protection. Re-run evasion test — EDR must detect or block. Verify Tamper Protection is active on all endpoints.

↑ HIGH

Indicator Removal: Clear Command History

T1070.003 - Test 4: Clear Bash history (In dev/null)

— APT41, APT5, Aquatic Panda

T1070.003 · Defense Evasion · Duration: 3ms · ART

✗ EVADED

WHAT HAPPENED

Security control did not prevent this technique — it executed without being blocked.

EXECUTED AS

User

△ Succeeded without administrator privileges. This technique is exploitable from any initial-access scenario — phishing, malicious document, or compromised standard account — before privilege escalation occurs. Prioritise remediation.

BLOCKED BY

✗ None — no control prevented this technique

DETECTION

✗ No detection — technique executed unseen

EXECUTION EVIDENCE

Exec Verdict

FAIL — technique ran to completion; no control blocked execution

Duration

3 ms

Framework

ART

CLEANUP & RESIDUAL RISK

Residual Risk

—

△ BUSINESS IMPACT

Security controls were bypassed on this endpoint. An attacker operating in this state can conduct further activity with a greatly reduced chance of detection or incident response.

► RECOMMENDED REMEDIATION

1) Enable tamper protection on all EDR/AV solutions; alert on protection disablement. 2) Restrict PowerShell to ConstrainedLanguageMode and enable AMSI. 3) Enable Script Block Logging (Event ID 4104) and forward to SIEM. 4) Monitor for security service termination and log clearing events.

► REMEDIATION PLAN

PRIORITY

High

ESTIMATED EFFORT

Days

OWNER

Endpoint Security Team

HOW TO VERIFY FIX

Enable additional EDR behavioral rules and Tamper Protection. Re-run evasion test — EDR must detect or block. Verify Tamper Protection is active on all endpoints.

↑ HIGH

Indicator Removal: Clear Command History

T1070.003 - Test 5: Clear Bash history (truncate)

— APT41, APT5, Aquatic Panda

T1070.003 · Defense Evasion · Duration: 3ms · ART

X EVADED

WHAT HAPPENED

Security control did not prevent this technique — it executed without being blocked.

EXECUTED AS

User

△ Succeeded without administrator privileges. This technique is exploitable from any initial-access scenario — phishing, malicious document, or compromised standard account — before privilege escalation occurs. Prioritise remediation.

BLOCKED BY

X None — no control prevented this technique

DETECTION

X No detection — technique executed unseen

EXECUTION EVIDENCE

Exec Verdict

FAIL — technique ran to completion; no control blocked execution

Duration

3 ms

Framework

ART

CLEANUP & RESIDUAL RISK

Residual Risk

—

△ BUSINESS IMPACT

Security controls were bypassed on this endpoint. An attacker operating in this state can conduct further activity with a greatly reduced chance of detection or incident response.

► RECOMMENDED REMEDIATION

1) Enable tamper protection on all EDR/AV solutions; alert on protection disablement. 2) Restrict PowerShell to ConstrainedLanguageMode and enable AMSI. 3) Enable Script Block Logging (Event ID 4104) and forward to SIEM. 4) Monitor for security service termination and log clearing events.

► REMEDIATION PLAN

PRIORITY

High

ESTIMATED EFFORT

Days

OWNER

Endpoint Security Team

HOW TO VERIFY FIX

Enable additional EDR behavioral rules and Tamper Protection. Re-run evasion test — EDR must detect or block. Verify Tamper Protection is active on all endpoints.

↑ HIGH

Indicator Removal: Clear Command History

T1070.003 - Test 6: Clear history of a bunch of shells

— APT41, APT5, Aquatic Panda

T1070.003 · Defense Evasion · Duration: 1ms · ART

X EVADED

WHAT HAPPENED

Security control did not prevent this technique — it executed without being blocked.

EXECUTED AS

User

△ Succeeded without administrator privileges. This technique is exploitable from any initial-access scenario — phishing, malicious document, or compromised standard account — before privilege escalation occurs. Prioritise remediation.

BLOCKED BY

X None — no control prevented this technique

DETECTION

X No detection — technique executed unseen

EXECUTION EVIDENCE

Exec Verdict

FAIL — technique ran to completion; no control blocked execution

Duration

1 ms

Framework

ART

CLEANUP & RESIDUAL RISK

Residual Risk

—

△ BUSINESS IMPACT

Security controls were bypassed on this endpoint. An attacker operating in this state can conduct further activity with a greatly reduced chance of detection or incident response.

► RECOMMENDED REMEDIATION

1) Enable tamper protection on all EDR/AV solutions; alert on protection disablement. 2) Restrict PowerShell to ConstrainedLanguageMode and enable AMSI. 3) Enable Script Block Logging (Event ID 4104) and forward to SIEM. 4) Monitor for security service termination and log clearing events.

► REMEDIATION PLAN

PRIORITY

High

ESTIMATED EFFORT

Days

OWNER

Endpoint Security Team

HOW TO VERIFY FIX

Enable additional EDR behavioral rules and Tamper Protection. Re-run evasion test — EDR must detect or block. Verify Tamper Protection is active on all endpoints.

↑ HIGH

Indicator Removal: Clear Command History

T1070.003 - Test 7: Clear and Disable Bash History Logging

— APT41, APT5, Aquatic Panda

T1070.003 · Defense Evasion · Duration: 23ms · ART

✗ EVADED

WHAT HAPPENED

Security control did not prevent this technique — it executed without being blocked.

EXECUTED AS

User

△ Succeeded without administrator privileges. This technique is exploitable from any initial-access scenario — phishing, malicious document, or compromised standard account — before privilege escalation occurs. Prioritise remediation.

BLOCKED BY

✗ None — no control prevented this technique

DETECTION

✗ No detection — technique executed unseen

EXECUTION EVIDENCE

Exec Verdict

FAIL — technique ran to completion; no control blocked execution

Duration

23 ms

Framework

ART

CLEANUP & RESIDUAL RISK

Residual Risk

—

△ BUSINESS IMPACT

Security controls were bypassed on this endpoint. An attacker operating in this state can conduct further activity with a greatly reduced chance of detection or incident response.

► RECOMMENDED REMEDIATION

1) Enable tamper protection on all EDR/AV solutions; alert on protection disablement. 2) Restrict PowerShell to ConstrainedLanguageMode and enable AMSI. 3) Enable Script Block Logging (Event ID 4104) and forward to SIEM. 4) Monitor for security service termination and log clearing events.

► REMEDIATION PLAN

PRIORITY

High

ESTIMATED EFFORT

Days

OWNER

Endpoint Security Team

HOW TO VERIFY FIX

Enable additional EDR behavioral rules and Tamper Protection. Re-run evasion test — EDR must detect or block. Verify Tamper Protection is active on all endpoints.

↑ HIGH

Indicator Removal: Clear Command History

T1070.003 - Test 8: Use Space Before Command to Avoid Logging to History

— APT41, APT5, Aquatic Panda

T1070.003 · Defense Evasion · Duration: 4ms · ART

✗ EVADED

WHAT HAPPENED

Security control did not prevent this technique — it executed without being blocked. Output: audspecterver

EXECUTED AS

User

△ Succeeded without administrator privileges. This technique is exploitable from any initial-access scenario — phishing, malicious document, or compromised standard account — before privilege escalation occurs. Prioritise remediation.

BLOCKED BY

✗ None — no control prevented this technique

DETECTION

✗ No detection — technique executed unseen

EXECUTION EVIDENCE

Exec Verdict

FAIL — technique ran to completion; no control blocked execution

Duration

4 ms

Framework

ART

CLEANUP & RESIDUAL RISK

Residual Risk

—

△ BUSINESS IMPACT

Security controls were bypassed on this endpoint. An attacker operating in this state can conduct further activity with a greatly reduced chance of detection or incident response.

► RECOMMENDED REMEDIATION

1) Enable tamper protection on all EDR/AV solutions; alert on protection disablement. 2) Restrict PowerShell to ConstrainedLanguageMode and enable AMSI. 3) Enable Script Block Logging (Event ID 4104) and forward to SIEM. 4) Monitor for security service termination and log clearing events.

► REMEDIATION PLAN

PRIORITY

High

ESTIMATED EFFORT

Days

OWNER

Endpoint Security Team

HOW TO VERIFY FIX

Enable additional EDR behavioral rules and Tamper Protection. Re-run evasion test — EDR must detect or block. Verify Tamper Protection is active on all endpoints.

WHAT HAPPENED

Security control did not prevent this technique — it executed without being blocked. Output: Deleted Containers:

EXECUTED AS

Admin

△ Requires elevated privileges to succeed. An attacker must first escalate from a standard user account before this technique becomes feasible. Focus on preventing privilege escalation and securing administrator credentials.

BLOCKED BY

✗ None — no control prevented this technique

DETECTION

✗ No detection — technique executed unseen

EXECUTION EVIDENCE

Exec Verdict

FAIL — technique ran to completion; no control blocked execution

Duration

412 ms

Framework

ART

CLEANUP & RESIDUAL RISK

Residual Risk

—

△ BUSINESS IMPACT

Security controls were bypassed on this endpoint. An attacker operating in this state can conduct further activity with a greatly reduced chance of detection or incident response.

► RECOMMENDED REMEDIATION

1) Enable tamper protection on all EDR/AV solutions; alert on protection disablement. 2) Restrict PowerShell to ConstrainedLanguageMode and enable AMSI. 3) Enable Script Block Logging (Event ID 4104) and forward to SIEM. 4) Monitor for security service termination and log clearing events.

► REMEDIATION PLAN

PRIORITY

High

ESTIMATED EFFORT

Days

OWNER

Endpoint Security Team

HOW TO VERIFY FIX

Enable additional EDR behavioral rules and Tamper Protection. Re-run evasion test — EDR must detect or block. Verify Tamper Protection is active on all endpoints.

WHAT HAPPENED

Security control did not prevent this technique — it executed without being blocked.

EXECUTED AS

User

△ Succeeded without administrator privileges. This technique is exploitable from any initial-access scenario — phishing, malicious document, or compromised standard account — before privilege escalation occurs. Prioritise remediation.

BLOCKED BY

✗ None — no control prevented this technique

DETECTION

✗ No detection — technique executed unseen

EXECUTION EVIDENCE

Exec Verdict

FAIL — technique ran to completion; no control blocked execution

Duration

23 ms

Framework

ART

CLEANUP & RESIDUAL RISK

Cleanup

✓ Reverted

Residual Risk

None

△ BUSINESS IMPACT

Security controls were bypassed on this endpoint. An attacker operating in this state can conduct further activity with a greatly reduced chance of detection or incident response.

► RECOMMENDED REMEDIATION

1) Enable tamper protection on all EDR/AV solutions; alert on protection disablement. 2) Restrict PowerShell to ConstrainedLanguageMode and enable AMSI. 3) Enable Script Block Logging (Event ID 4104) and forward to SIEM. 4) Monitor for security service termination and log clearing events.

► REMEDIATION PLAN

PRIORITY

High

ESTIMATED EFFORT

Days

OWNER

Endpoint Security Team

HOW TO VERIFY FIX

Enable additional EDR behavioral rules and Tamper Protection. Re-run evasion test — EDR must detect or block. Verify Tamper Protection is active on all endpoints.

↑ HIGH

Indicator Removal

T1070.006 - Test 2: Set a file's modification timestamp

— APT28, APT29, APT32

T1070.006 · Defense Evasion · Duration: 26ms · ART

WHAT HAPPENED

Security control did not prevent this technique — it executed without being blocked.

EXECUTED AS

User

△ Succeeded without administrator privileges. This technique is exploitable from any initial-access scenario — phishing, malicious document, or compromised standard account — before privilege escalation occurs. Prioritise remediation.

BLOCKED BY

✗ None — no control prevented this technique

DETECTION

✗ No detection — technique executed unseen

EXECUTION EVIDENCE

Exec Verdict

FAIL — technique ran to completion; no control blocked execution

Duration

26 ms

Framework

ART

CLEANUP & RESIDUAL RISK

Residual Risk

—

△ BUSINESS IMPACT

Security controls were bypassed on this endpoint. An attacker operating in this state can conduct further activity with a greatly reduced chance of detection or incident response.

► RECOMMENDED REMEDIATION

1) Enable tamper protection on all EDR/AV solutions; alert on protection disablement. 2) Restrict PowerShell to ConstrainedLanguageMode and enable AMSI. 3) Enable Script Block Logging (Event ID 4104) and forward to SIEM. 4) Monitor for security service termination and log clearing events.

► REMEDIATION PLAN

PRIORITY

High

ESTIMATED EFFORT

Days

OWNER

Endpoint Security Team

HOW TO VERIFY FIX

Enable additional EDR behavioral rules and Tamper Protection. Re-run evasion test — EDR must detect or block. Verify Tamper Protection is active on all endpoints.

↑ HIGH

Indicator Removal

T1070.006 - Test 3: Set a file's creation timestamp

— APT28, APT29, APT32

T1070.006 · Defense Evasion · Duration: 29ms · ART

WHAT HAPPENED

Security control did not prevent this technique — it executed without being blocked. Output: Fri Jan 1 12:00:00 AM UTC 1971

EXECUTED AS

Admin

△ Requires elevated privileges to succeed. An attacker must first escalate from a standard user account before this technique becomes feasible. Focus on preventing privilege escalation and securing administrator credentials.

BLOCKED BY

✗ None — no control prevented this technique

DETECTION

✗ No detection — technique executed unseen

EXECUTION EVIDENCE

Exec Verdict

FAIL — technique ran to completion; no control blocked execution

Duration

29 ms

Framework

ART

CLEANUP & RESIDUAL RISK

Residual Risk

—

△ BUSINESS IMPACT

Security controls were bypassed on this endpoint. An attacker operating in this state can conduct further activity with a greatly reduced chance of detection or incident response.

► RECOMMENDED REMEDIATION

1) Enable tamper protection on all EDR/AV solutions; alert on protection disablement. 2) Restrict PowerShell to ConstrainedLanguageMode and enable AMSI. 3) Enable Script Block Logging (Event ID 4104) and forward to SIEM. 4) Monitor for security service termination and log clearing events.

► REMEDIATION PLAN

PRIORITY

High

ESTIMATED EFFORT

Days

OWNER

Endpoint Security Team

HOW TO VERIFY FIX

Enable additional EDR behavioral rules and Tamper Protection. Re-run evasion test — EDR must detect or block. Verify Tamper Protection is active on all endpoints.

Environment Restoration

Documents whether all simulation-induced environment changes were successfully reverted. Answers the key enterprise question: "Did the BAS restore everything it touched?"

✓

ENVIRONMENT RESTORATION

Successful

No Persistent Changes

All 7 simulation-induced changes were reverted. No persistent modifications remain on the endpoint. 6 of these were cleaned by the safety-net sweep, not by their own script.

CLEANUP SUCCESS RATE

100.0%

stepsCleaned / (cleaned + leaked)

COVERAGE RATE

41%

Steps with cleanup defined

STEPS CLEANED

7

of 7 cleanup-capable

STEPS LEAKED

0

cleanup failed or timed out

AGENT-CONFIRMED ROLLBACKS

2

endpoint changes confirmed reverted

NO CLEANUP DEFINED

10

steps with no cleanup command

Agent-Confirmed Rollbacks

Endpoint changes confirmed reverted by the agent post-run.

- iptables: rules restored
- tmp removed: /tmp/bas-18d1ccdd6d7085e9-4058278856

SECTION 18

Detection Validation

Per-technique outcome from the post-run EDR/alert sweep. **PREVENTED** = control blocked execution before it could run. **DETECTED** = technique executed and the security control raised an alert (detection source shown). **UNDETECTED** = technique executed with no alert — the security gap an attacker would exploit silently. Techniques where the agent has not yet submitted detection telemetry show "NO DATA".

DETECTION SOURCE RANKING

Ranking of security products based on total detection count (most often) and speed (first to detect/lowest minimum MTTD).

RANK	PRODUCT	DETECTIONS	MIN TIME-TO-DETECT	AVG TIME-TO-DETECT
#1	Trellix	18	4s	8s
#2	Defender	14	2s	4s
#3	SIEM	5	12s	25s

TECHNIQUE	TACTIC	SEV	EXECUTION	REQUESTED PRIV	EXECUTED AS	DETECTION	ALERT SOURCE	EVENT ID	THREAT / PROCESS	MTTD	CLEANUP	BLOCKING CONTROL
T1070.003 Indicator Removal: Clear Command History T1070.003 - Test 1: Clear Bash history (rm)	Defense Evasion	● High	FAIL	User	User	NO DATA		—		—	—	—
T1070.003 Indicator Removal: Clear Command History	Defense Evasion	● High	FAIL	User	User	NO DATA		—		—	—	—

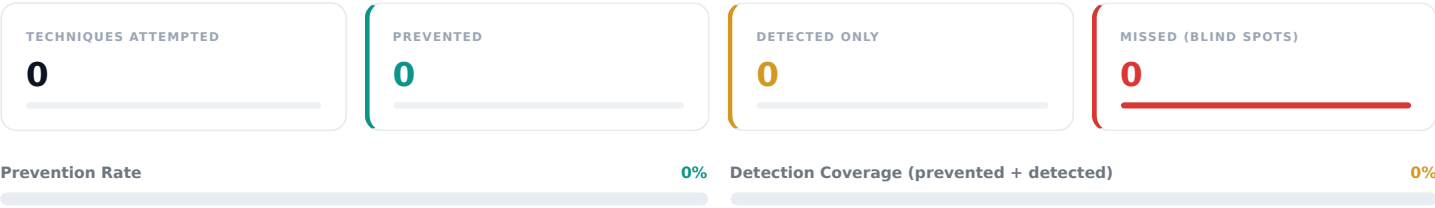
Technique	Tactic	Sev	Execution	Requested Priv	Executed As	Detection	Alert Source	Event ID	Threat / Process	MTTD	Cleanup	Blocking Control
T1070.003 - Test 2: Clear Bash history (echo)												
T1070.003 Indicator Removal: Clear Command History T1070.003 - Test 3: Clear Bash history (cat dev/null)	Defense Evasion	● High	FAIL	User	User	NO DATA		—		—	—	—
T1070.003 Indicator Removal: Clear Command History T1070.003 - Test 4: Clear Bash history (ln dev/null)	Defense Evasion	● High	FAIL	User	User	NO DATA		—		—	—	—
T1070.003 Indicator Removal: Clear Command History T1070.003 - Test 5: Clear Bash history (truncate)	Defense Evasion	● High	FAIL	User	User	NO DATA		—		—	—	—
T1070.003 Indicator Removal: Clear Command History T1070.003 - Test 6: Clear history of a bunch of shells	Defense Evasion	● High	FAIL	User	User	NO DATA		—		—	—	—
T1070.003 Indicator Removal: Clear Command History T1070.003 - Test 7: Clear and Disable Bash History Logging	Defense Evasion	● High	FAIL	User	User	NO DATA		—		—	—	—
T1070.003 Indicator Removal: Clear Command History T1070.003 - Test 8: Use Space Before Command to Avoid Logging to History	Defense Evasion	● High	FAIL	User	User	NO DATA		—		—	—	—
T1070.003 Indicator Removal: Clear Command History T1070.003 -	Defense Evasion	● High	ERROR	User	User	NO DATA		—		—	—	—

TECHNIQUE	TACTIC	SEV	EXECUTION	REQUESTED PRIV	EXECUTED AS	DETECTION	ALERT SOURCE	EVENT ID	THREAT / PROCESS	MTTD	CLEANUP	BLOCKING CONTROL
Test 9: Disable Bash History Logging with SSH -T												
T1070.003 Indicator Removal: Clear Command History T1070.003 - Test 10: Clear Docker Container Logs	Defense Evasion	● High	FAIL	Admin	Admin	NO DATA		—		—	—	—
T1070.006 Indicator Removal T1070.006 - Test 1: Set a file's access timestamp	Defense Evasion	● High	FAIL	User	User	NO DATA		—		—	REVERTED	—
T1070.006 Indicator Removal T1070.006 - Test 2: Set a file's modification timestamp	Defense Evasion	● High	FAIL	User	User	NO DATA		—		—	—	—
T1070.006 Indicator Removal T1070.006 - Test 3: Set a file's creation timestamp	Defense Evasion	● High	FAIL	Admin	Admin	NO DATA		—		—	—	—
T1070.006 Indicator Removal T1070.006 - Test 4: Modify file timestamps using reference file	Defense Evasion	● High	FAIL	User	User	NO DATA		—		—	—	—
T1036.005 Masquerading: Match Legitimate Name or Location T1036.005 - Test 1: Execute a process from a directory masquerading as the current parent directory	Defense Evasion	● High	FAIL	User	User	NO DATA		—		—	—	—
T1070.002 Indicator Removal T1070.002	Defense Evasion	● High	SKIPPED	Legacy	Legacy	NO DATA		—		—	—	—
T1562.001 Impair Defenses: Disable or Modify Tools T1562.001	Defense Evasion	● High	SKIPPED	Legacy	Legacy	NO DATA		—		—	—	—

SECTION 19

Coverage Analytics

3-bucket breakdown of every technique executed in this assessment. **Prevented** — a control blocked execution (PASS/BLOCKED). **Detected Only** — execution succeeded but an EDR or SIEM alert fired (FAIL + detection). **Missed** — execution succeeded with no detection signal (highest risk, immediate remediation priority). ERROR and SKIPPED results are excluded.



SECTION 20

Technical Appendix — ATT&CK Glossary

Authoritative MITRE ATT&CK reference for every technique exercised in this assessment. Sourced from the bundled ATT&CK enterprise data.

T1036.005 — MATCH LEGITIMATE NAME OR LOCATION (DEFENSE EVASION)

Adversaries may match or approximate the name or location of legitimate files or resources when naming/placing them. This is done for the sake of evading defenses and observation. This may be done by placing an executable in a commonly trusted directory (ex: under System32) or giving it the name of a legitimate, trusted program (ex: svchost.exe). In containerized environments, this may also be done by creating a resource in a namespace that matches the naming convention of a container pod or cluster.

Detection: Collect file hashes; file names that do not match their expected hash are suspect. Perform file monitoring; files with known names but in unusual locations are suspect. Likewise, files that are modified outside of an update or patch are suspect. If file names are mismatched between the file name on disk and that of the binary's PE metadata, this is a likely indicator that a binary was renamed after it was compiled.

Data sources: File: File Metadata, Image: Image Metadata, Process: Process Creation, Process: Process Metadata

Mitigations: Code Signing, Execution Prevention, Restrict File and Directory Permissions

<https://attack.mitre.org/techniques/T1036/005>

T1070.002 — CLEAR LINUX OR MAC SYSTEM LOGS (DEFENSE EVASION)

Adversaries may clear system logs to hide evidence of an intrusion. macOS and Linux both keep track of system or user-initiated actions via system logs. The majority of native system logging is stored under the `/var/log/` directory. Subfolders in this directory categorize logs by their related functions, such as:(Citation: Linux Logs) * `/var/log/messages`: General and system-related messages * `/var/log/secure` or `/var/log/auth.log`: Authentication logs * `/var/log/utmp` or `/var/log/wtmp`: Login records * `/var/log/ker...`

Detection: File system monitoring may be used to detect improper deletion or modification of indicator files. Also monitor for suspicious processes interacting with log files.

Data sources: Command: Command Execution, File: File Deletion, File: File Modification

Mitigations: Encrypt Sensitive Information, Indicator Removal on Host Mitigation, Remote Data Storage, Restrict File and Directory Permissions

<https://attack.mitre.org/techniques/T1070/002>

T1070.003 — CLEAR COMMAND HISTORY (DEFENSE EVASION)

In addition to clearing system logs, an adversary may clear the command history of a compromised account to conceal the actions undertaken during an intrusion. Various command interpreters keep track of the commands users type in their terminal so that users can retrace what they've done. On Linux and macOS, these command histories can be accessed in a few different ways. While logged in, this command history is tracked in a file pointed to by the environment variable `HISTFILE`.

Detection: User authentication, especially via remote terminal services like SSH, without new entries in that user's `~/.bash_history` is suspicious. Additionally, the removal/clearing of the `~/.bash_history` file can be an indicator of suspicious activity. Monitor for suspicious modifications or deletion of `ConsoleHost_history.txt` and use of the `Clear-History` command.

Data sources: Command: Command Execution, File: File Deletion, File: File Modification, Process: Process Creation, User Account: User Account Authentication

Mitigations: Clear Command History Mitigation, Environment Variable Permissions, Remote Data Storage, Restrict File and Directory Permissions

<https://attack.mitre.org/techniques/T1070/003>

Adversaries may modify file time attributes to hide new files or changes to existing files. Timestomping is a technique that modifies the timestamps of a file (the modify, access, create, and change times), often to mimic files that are in the same folder and blend malicious files with legitimate files.

Detection: Forensic techniques exist to detect aspects of files that have had their timestamps modified. (Citation: WindowsIR Anti-Forensic Techniques) It may be possible to detect timestomping using file modification monitoring that collects information on file handle opens and can compare timestamp values.

Data sources: Command: Command Execution, File: File Metadata, File: File Modification, Process: OS API Execution

Mitigations: Timestomp Mitigation

<https://attack.mitre.org/techniques/T1070/006>

T1562.001 — DISABLE OR MODIFY TOOLS (DEFENSE EVASION)

Adversaries may modify and/or disable security tools to avoid possible detection of their malware/tools and activities. This may take many forms, such as killing security software processes or services, modifying / deleting Registry keys or configuration files so that tools do not operate properly, or other methods to interfere with security tools scanning or reporting information.

Detection: Monitor processes and command-line arguments to see if security tools/services are killed or stop running. Monitor Registry edits for modifications to services and startup programs that correspond to security tools. Monitoring for changes to other known features used by deployed security tools may also expose malicious activity. Lack of expected log events may be suspicious.

Data sources: Command: Command Execution, Driver: Driver Load, Process: Process Creation, Process: Process Termination, Sensor Health: Host Status, Service: Service Metadata, Windows Registry: Windows Registry Key Deletion, Windows Registry: Windows Registry Key Modification

Mitigations: Execution Prevention, Restrict File and Directory Permissions, Restrict Registry Permissions, User Account Management

<https://attack.mitre.org/techniques/T1562/001>